

04 — API Spec Draft (FinCloud)

Penulis	Muhamad Farrel — Backend / API Developer
Status	Draft Minggu 1 (belum final, menunggu review Sahrul & Feeandri)
Issue	#2 Draft API spec
Terkait	03-erd-draft.md, 07-security-checklist.md, 06-storage-backup-plan.md, docs/frontend-requirements.md

Dokumen ini adalah kontrak antara backend dan frontend. Detail di sini bisa berubah setelah review; perubahan dicatat di bagian **Changelog**.

1. Konvensi Umum

1.1 Base URL & format

- Base URL: `/api` (contoh lokal: `http://localhost:8080/api`)
- Content-Type: `application/json` (kecuali upload: `multipart/form-data`)
- Nama field: `snake_case`
- Tanggal: `YYYY-MM-DD`; timestamp: ISO 8601 UTC (`2026-10-05T08:30:00Z`)
- Nominal uang: **integer dalam Rupiah** (tanpa desimal), tidak boleh `float`. Contoh: `150000`
- ID: integer (atau UUID, menunggu keputusan ERD)

1.2 Format response sukses

```
{
  "success": true,
  "message": "Transaksi berhasil dibuat",
  "data": { }
}
```

Untuk list, ditambah meta:

```
{
  "success": true,
  "message": "OK",
  "data": [ ],
  "meta": { "page": 1, "limit": 10, "total": 57, "total_pages": 6 }
}
```

1.3 Format response error

```
{
  "success": false,
  "message": "Validasi gagal",
  "code": "VALIDATION_ERROR",
  "errors": [
    { "field": "amount", "message": "amount harus lebih dari 0" }
  ]
}
```

errors hanya diisi untuk error validasi. Pesan error tidak boleh membocorkan detail internal (stack trace, query SQL).

1.4 Status code

Code	Kapan dipakai	code error
200	GET / PUT / DELETE berhasil	—
201	Resource baru dibuat	—
400	Request malformed	BAD_REQUEST
401	Token tidak ada / invalid / kedaluwarsa, atau login salah	UNAUTHORIZED, INVALID_CREDENTIALS, TOKEN_EXPIRED
403	Login valid tapi role tidak cukup / akun nonaktif	FORBIDDEN
404	Resource tidak ada atau milik user lain	NOT_FOUND
409	Konflik (email sudah terdaftar)	CONFLICT
413	File upload terlalu besar	FILE_TOO_LARGE
415	Tipe file tidak didukung	UNSUPPORTED_MEDIA_TYPE
422	Validasi field gagal	VALIDATION_ERROR
429	Terlalu banyak request (rate limit)	RATE_LIMITED
500	Error server	INTERNAL_ERROR

1.5 Pagination, filter, sorting (endpoint list)

Query standar: ?page=1&limit=10&sort=transaction_date&order=desc

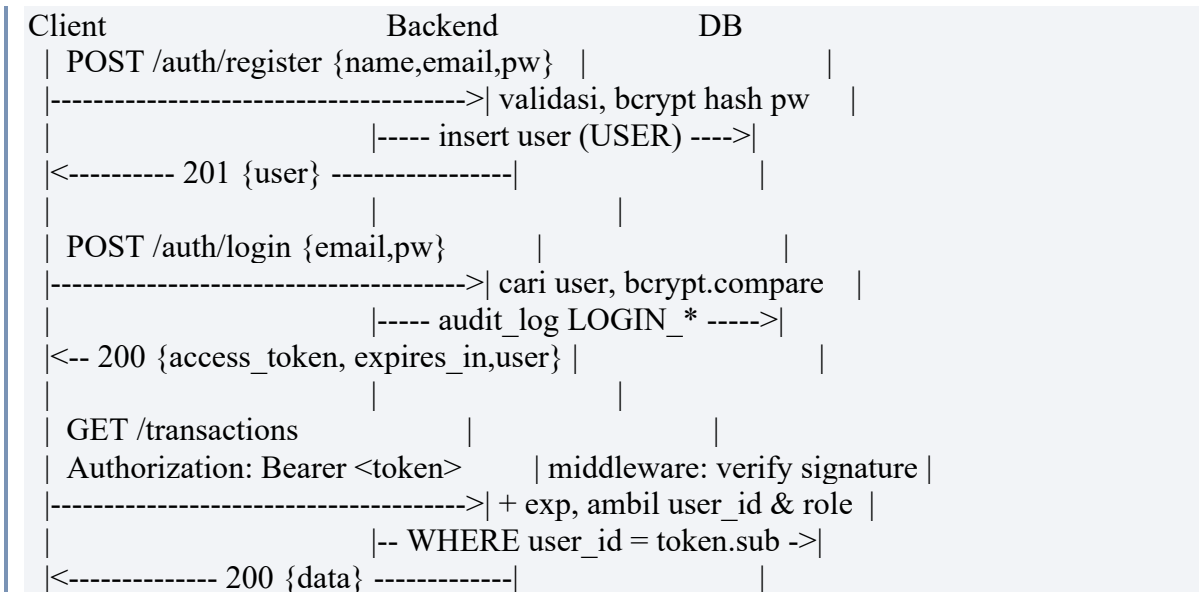
- Default page=1, limit=10, maksimum limit=100.

1.6 Autentikasi header

Authorization: Bearer <access_token>

Kolom **Auth** pada tabel endpoint: Publik = tanpa token, USER = token valid, ADMIN = token valid dengan role ADMIN.

2. Alur JWT



Ketentuan:

- Password di-hash dengan **bcrypt** (cost 10–12); password tidak pernah disimpan atau dilog dalam bentuk asli.
- Access token: JWT, algoritma **HS256**, masa berlaku **1 jam** (**JWT_EXPIRES_IN**), secret dari env var **JWT_SECRET**.
- Payload token: { "sub": <user_id>, "role": "USER" | "ADMIN", "iat": ..., "exp": ... }. Tidak ada data sensitif di payload.
- Register selalu membuat role **USER**. Role **ADMIN** hanya dibuat lewat seed / script, bukan lewat API publik.
- Middleware **authenticate**: verifikasi signature dan exp, lalu isi req.user = { id, role }. Middleware **requireRole('ADMIN')** dipasang di semua route **/api/admin/***.
- **Data isolation**: semua query data keuangan wajib memakai **user_id** dari token, **bukan** dari body/query. Akses ke resource user lain dibalas 404 (bukan 403) agar keberadaan data tidak bocor.
- Logout: stateless, cukup hapus token di client (tidak ada endpoint). Refresh token = opsional / bonus (lihat Pertanyaan Terbuka).
- Rate limit: **POST /auth/login** dan **POST /auth/register** maks. 5 request/menit/IP (angka bisa disesuaikan dengan Sahrul).

3. Ringkasan Endpoint (Minimum)

#	Method	Path	Auth	Deskripsi
Auth				
1	POST	/auth/register	Publik	Daftar akun baru
2	POST	/auth/login	Publik	Login, dapat JWT

#	Method	Path	Auth	Deskripsi
Profile				
3	GET	/profile	USER	Lihat profil sendiri
4	PUT	/profile	USER	Ubah nama
5	PUT	/profile/password	USER	Ganti password
Kategori				
6	GET	/categories	USER	Daftar kategori (untuk dropdown)
Transaksi				
7	GET	/transactions	USER	List transaksi (filter + pagination)
8	POST	/transactions	USER	Tambah transaksi
9	GET	/transactions/:id	USER	Detail transaksi
10	PUT	/transactions/:id	USER	Ubah transaksi
11	DELETE	/transactions/:id	USER	Hapus transaksi
Upload receipt				
12	POST	/transactions/:id/receipts	USER	Upload bukti transaksi
13	GET	/transactions/:id/receipts	USER	List receipt milik transaksi
14	GET	/receipts/:id/download	USER	Unduh / lihat file receipt
15	DELETE	/receipts/:id	USER	Hapus receipt
Dashboard				
16	GET	/dashboard/summary	USER	Saldo + pemasukan vs pengeluaran
17	GET	/dashboard/charts/by-category	USER	Data chart pengeluaran per kategori
18	GET	/dashboard/charts/trend	USER	Data chart tren per hari/bulan
Report				
19	GET	/reports/monthly	USER	Laporan bulanan
20	GET	/reports/monthly/export	USER	Export laporan bulanan (CSV) — <i>bonus</i>
Admin				
21	GET	/admin/users	ADMIN	List semua user
22	PATCH	/admin/users/:id/status	ADMIN	Aktifkan / nonaktifkan user
23	POST	/admin/categories	ADMIN	Tambah kategori

#	Method	Path	Auth	Deskripsi
24	PUT	/admin/categories/:id	ADMIN	Ubah kategori
25	DELETE	/admin/categories/:id	ADMIN	Hapus kategori
26	GET	/admin/audit-logs	ADMIN	Lihat audit log (filter + pagination)
27	GET	/admin/stats	ADMIN	Statistik agregat sistem
Sistem				
28	GET	/health	Publik	Health check (untuk Docker/monitoring)

/health berada di root (bukan di bawah /api) bila lebih mudah untuk healthcheck container; disepakati dengan Kenjiro & Ihsanul.

4. Detail Endpoint

4.1 Auth

POST /auth/register

Request:

```
{ "name": "Budi Santoso", "email": "budi@mail.com", "password": "Rahasia123" }
```

Validasi: name 2–100 karakter; email format valid & unik; password min. 8 karakter, mengandung huruf dan angka.

Response 201:

```
{
  "success": true,
  "message": "Registrasi berhasil",
  "data": { "id": 1, "name": "Budi Santoso", "email": "budi@mail.com", "role": "USER" }
}
```

Error: 409 CONFLICT (email sudah terdaftar), 422 VALIDATION_ERROR.

POST /auth/login

Request:

```
{ "email": "budi@mail.com", "password": "Rahasia123" }
```

Response 200:

```
{
  "success": true,
  "message": "Login berhasil",
  "data": {
    "access_token": "eyJhbGciOi...",
    "token_type": "Bearer",
    "expires_in": 3600,
    "user": { "id": 1, "name": "Budi Santoso", "email": "budi@mail.com", "role": "USER" }
  }
}
```

Error: 401 INVALID_CREDENTIALS (pesan sama untuk email salah maupun password salah), 403 FORBIDDEN (akun dinonaktifkan), 429 RATE_LIMITED. Audit log: LOGIN_SUCCESS / LOGIN_FAILED.

4.2 Profile

- GET /profile → data: { id, name, email, role, created_at }
- PUT /profile — body { "name": "Budi S." } → 200 profil terbaru. Email tidak dapat diubah pada versi ini.
- PUT /profile/password — body { "current_password": "...", "new_password": "..." } → 200; 401 bila password lama salah.

4.3 Kategori

GET /categories

Query optional: ?type=INCOME|EXPENSE

Response 200:

```
{
  "success": true,
  "message": "OK",
  "data": [
    { "id": 1, "name": "Gaji", "type": "INCOME" },
    { "id": 2, "name": "Makanan", "type": "EXPENSE" }
  ]
}
```

4.4 Transaksi

Atribut transaksi (minimum, menyesuaikan 03-erd-draft.md):

Field	Tipe	Keterangan
id	int	Dibuat server
type	enum	INCOME atau EXPENSE
category_id	int	Harus ada dan type kategori sama dengan type transaksi
amount	int	Rupiah, > 0

Field	Tipe	Keterangan
transaction_date	date	YYYY-MM-DD, tidak boleh lebih dari hari ini + 1 (konfirmasi)
description	string	Opsional, maks. 255 karakter
created_at, updated_at	timestamp	Dibuat server

user_id **tidak** dikirim client; diambil dari token.

GET /transactions

Query: page, limit, type, category_id, start_date, end_date, search (di description), sort (transaction_date | amount | created_at), order (asc | desc).

Response 200:

```
{
  "success": true,
  "message": "OK",
  "data": [
    {
      "id": 12,
      "type": "EXPENSE",
      "amount": 45000,
      "transaction_date": "2026-10-03",
      "description": "Makan siang",
      "category": { "id": 2, "name": "Makanan" },
      "receipt_count": 1
    }
  ],
  "meta": { "page": 1, "limit": 10, "total": 57, "total_pages": 6 }
}
```

POST /transactions

Request:

```
{
  "type": "EXPENSE",
  "category_id": 2,
  "amount": 45000,
  "transaction_date": "2026-10-03",
  "description": "Makan siang"
}
```

Response 201: objek transaksi lengkap. Error 422 bila amount ≤ 0 /kosong/bukan integer, category_id tidak valid, atau type tidak cocok dengan kategori. Audit log: TRANSACTION_CREATE.

GET /transactions/:id

Response 200: objek transaksi + array receipts. 404 bila tidak ada atau bukan milik user.

PUT /transactions/:id

Body sama dengan POST. Response 200: transaksi terbaru. Audit log: TRANSACTION_UPDATE.

DELETE /transactions/:id

Response 200: { "success": true, "message": "Transaksi dihapus", "data": null }. Receipt terkait ikut dihapus (DB + objek di MinIO). Audit log: TRANSACTION_DELETE.

Saldo tidak disimpan sebagai kolom terpisah pada versi ini; dihitung dari SUM(INCOME) – SUM(EXPENSE) per user (lihat 4.6). Karena itu edit/hapus transaksi otomatis tercermin di saldo tanpa penyesuaian manual. Operasi tulis yang menyentuh beberapa tabel (mis. hapus transaksi + receipt) dijalankan dalam satu DB transaction.

4.5 Upload Receipt

Alur (sesuai 06-storage-backup-plan.md): **frontend** → **backend** → **MinIO** → **simpan metadata di DB**.

POST /transactions/:id/receipts

- Content-Type: multipart/form-data, field file: file
- Tipe yang diizinkan: image/jpeg, image/png, application/pdf
- Ukuran maksimum: 5 MB (MAX_UPLOAD_MB)
- Validasi tipe berdasarkan isi/MIME server-side, bukan hanya ekstensi
- Nama objek di MinIO dibuat server: receipts/{user_id}/{transaction_id}/{uuid}.{ext} (nama file asli hanya disimpan sebagai metadata)

Response 201:

```
{
  "success": true,
  "message": "Receipt berhasil diunggah",
  "data": {
    "id": 5,
    "transaction_id": 12,
    "original_filename": "struk.jpg",
    "content_type": "image/jpeg",
    "size_bytes": 182340,
    "uploaded_at": "2026-10-03T09:15:00Z"
  }
}
```

Error: 404 (transaksi bukan milik user), 413, 415. Audit log: RECEIPT_UPLOAD.

- GET /transactions/:id/receipts → daftar metadata receipt.
- GET /receipts/:id/download → stream file dengan Content-Type sesuai (backend memeriksa kepemilikan lebih dulu; bucket MinIO tidak dibuka publik).
- DELETE /receipts/:id → 200, hapus objek + metadata.

4.6 Dashboard

Semua endpoint dashboard hanya membaca data milik user pada token. Query month=YYYY-MM opsional (default: bulan berjalan).

GET /dashboard/summary

Response 200:

```
{
  "success": true,
  "message": "OK",
  "data": {
    "balance": 3250000,
    "month": "2026-10",
    "total_income": 5000000,
    "total_expense": 1750000,
    "net": 3250000,
    "transaction_count": 18,
    "recent_transactions": [ ]
  }
}
```

balance = total seluruh waktu; total_income/total_expense = untuk bulan yang dipilih.
recent_transactions berisi 5 transaksi terbaru.

GET /dashboard/charts/by-category

Query: month, type (default EXPENSE).

```
{
  "success": true,
  "message": "OK",
  "data": [
    { "category_id": 2, "category": "Makanan", "total": 750000, "percentage": 42.86 },
    { "category_id": 3, "category": "Transport", "total": 400000, "percentage": 22.86 }
  ]
}
```

GET /dashboard/charts/trend

Query: start_date, end_date, interval (day | month, default day).

```
{
  "success": true,
  "message": "OK",
  "data": [
    { "period": "2026-10-01", "income": 0, "expense": 45000 },
    { "period": "2026-10-02", "income": 5000000, "expense": 120000 }
  ]
}
```

Catatan performa: agregasi dikerjakan di database (SUM ... GROUP BY), bukan di aplikasi; butuh index (user_id, transaction_date) — diusulkan ke Feeandri.

4.7 Report

GET /reports/monthly

Query wajib: month=YYYY-MM.

```
{
  "success": true,
  "message": "OK",
  "data": {
    "month": "2026-10",
    "total_income": 5000000,
    "total_expense": 1750000,
    "net": 3250000,
    "by_category": [
      { "category": "Makanan", "type": "EXPENSE", "total": 750000, "count": 12 }
    ],
    "transactions": [ ]
  }
}
```

transactions mengikuti pagination standar bila jumlahnya besar (page, limit).

GET /reports/monthly/export (bonus)

Query: month=YYYY-MM, format=csv. Response 200 dengan Content-Type: text/csv dan header Content-Disposition: attachment; filename="fincloud-2026-10.csv".

4.8 Admin

Semua route di bawah /api/admin/* mensyaratkan role ADMIN; user biasa mendapat 403.

- GET /admin/users — query: page, limit, search (nama/email), status. Data: id, name, email, role, is_active, created_at. **Tidak** memuat password hash.
- PATCH /admin/users/:id/status — body { "is_active": false }. Admin tidak boleh menonaktifkan akunnya sendiri (400). Audit log: USER_STATUS_CHANGE.
- POST /admin/categories — body { "name": "Hiburan", "type": "EXPENSE" } → 201.
- PUT /admin/categories/:id — body sama → 200.
- DELETE /admin/categories/:id — 409 bila kategori masih dipakai transaksi.
- GET /admin/audit-logs — query: page, limit, event, user_id, start_date, end_date.

```
{
  "success": true,
  "message": "OK",
  "data": [
    {
      "id": 101,
      "user_id": 1,
      "event": "LOGIN_FAILED",
      "ip_address": "10.0.0.5",
      "detail": { "email": "budi@mail.com" },
      "created_at": "2026-10-03T09:10:00Z"
    }
  ],
  "meta": { "page": 1, "limit": 10, "total": 240, "total_pages": 24 }
}
```

- GET /admin/stats — hanya **agregat** (jumlah user, jumlah transaksi, jumlah receipt, user aktif); admin tidak membaca isi transaksi user.

4.9 Sistem

GET /health

```
{ "status": "ok", "database": "up", "storage": "up", "uptime_seconds": 12345 }
```

200 bila semua dependensi sehat, 503 bila ada yang down. Tanpa autentikasi dan tanpa data sensitif.

5. Audit Log (Selaras dengan Sahrul)

Event	Dicatat saat
LOGIN_SUCCESS	Login berhasil
LOGIN_FAILED	Login gagal (jangan catat password)
REGISTER	Akun baru dibuat
TRANSACTION_CREATE / _UPDATE / _DELETE	CRUD transaksi
RECEIPT_UPLOAD / RECEIPT_DELETE	Upload / hapus receipt
USER_STATUS_CHANGE	Admin mengubah status user

6. Catatan Keamanan Singkat

- Secret (JWT_SECRET, kredensial DB, kunci MinIO) hanya dari env var / .env (tidak di-commit).
 - Validasi input di server untuk semua endpoint; query DB memakai parameterized query / ORM.
 - CORS hanya mengizinkan origin frontend; pasang security headers (mis. helmet).
 - Jangan log password, token, atau isi header Authorization.
 - Response user tidak pernah memuat password_hash.
-